

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/30/2025
Référence: Gestion de crise cyber
Destinataire: Max

****Document: Plan de Réponse à une Attaque Avancée par Ransomware****

****Domaine:**** Gestion de crise cyber

****Niveau de difficulté:**** Expert

****Contact:**** Lorenzo Bertola

****Destinataire:**** Max

****Contexte de l'incident****

Le système d'information de l'entreprise a été compromis par une attaque avancée de type ransomware. Les premières analyses indiquent que le malware a été déployé dans le réseau interne via un vecteur de phishing ciblé. Les systèmes critiques ont été chiffrés, rendant indisponibles plusieurs services stratégiques. Une demande de rançon a été reçue, exigeant un paiement en crypto-monnaie dans les 72 heures sous peine de destruction définitive des données chiffrées.

Le ransomware semble appartenir à une famille bien documentée (ex: LockBit, REvil), mais avec des capacités de persistance améliorées, incluant l'utilisation de techniques d'évasion avancées et un chiffrement asymétrique renforcé. Les logs montrent des activités non autorisées remontant à au moins deux semaines avant le déclenchement de l'attaque.

****Périmètre impacté****

- ****Systèmes touchés :** Serveurs de fichiers, bases de données ERP, postes de travail utilisateurs.
- ****Réseaux :** Segment interne principal et connexions VPN.
- ****Applications :** Systèmes de gestion client (CRM) et outils métiers critiques.
- ****Données :** Chiffrement des fichiers sensibles (contrats, rapports financiers, données RH).

****Indicateurs d'attaque (IoC)****

- Fichiers avec extensions inhabituelles (.encrypted, .lockbit).
- Présence de processus malveillants (ex: nom aléatoire ou masqué sous des noms légitimes).
- Communications suspectes avec des serveurs externes via des protocoles chiffrés (ex: HTTPS sur des domaines inconnus).
- Modifications dans les paramètres de stratégie de groupe (GPO) pour désactiver les sauvegardes automatiques.
- Détection d'outils de mouvement latéral (ex: Mimikatz, PsExec).

****Chronologie de l'incident****

1. ****J-14:**** Premières connexions suspectes depuis un VPN externe.
2. ****J-7:**** Augmentation anormale du trafic réseau entre plusieurs segments internes.
3. ****J-3:**** Déploiement du ransomware sur les postes de travail et serveurs.
4. ****J-0:**** Chiffrement complet des données critiques et affichage de la demande de rançon.

****Enjeux stratégiques****

- ****Opérationnels :**** Rétablissement des services métiers critiques.
- ****Financiers :**** Réduction des pertes potentielles liées à l'interruption des activités.
- ****Réputation :**** Prévention de la divulgation des données sensibles volées et protection de la marque.
- ****Légaux :**** Conformité avec les réglementations en cas de fuite de données personnelles (ex: RGPD).

****Ressources disponibles****

- ****Équipe technique :**** SOC interne, administrateurs système, analystes cybersécurité.
- ****Outils :**** SIEM, EDR/XDR, analyseurs de trafic réseau, sauvegardes hors-ligne.
- ****Références externes :**** Centre de réponse aux incidents (CERT), partenaires en cybersécurité.
- ****Historique :**** Documentation des attaques similaires sur des entreprises du même secteur.

****Points de réflexion pour Max****

1. ****Analyse :**** Comment identifier rapidement la portée exacte de l'infection ? Quels outils ou techniques privilégier pour l'investigation ?
2. ****Isolation :**** Quelle stratégie mettre en place pour contenir l'attaque sans aggraver la situation ?
3. ****Communication :**** Comment structurer une communication interne/externe adaptée à l'urgence et aux enjeux ?
4. ****Récupération :**** Quelles étapes prioriser pour restaurer les systèmes tout en minimisant les risques de réinfection ?
5. ****Décision stratégique :**** Comment évaluer les implications d'un éventuel paiement de la rançon ?

****Note de Lorenzo Bertola****

Max, cette situation requiert une approche méthodique et une prise de décision rapide. Utilise les indicateurs fournis, le contexte technique et les ressources disponibles pour structurer ta réponse. N'oublie pas de documenter chaque étape de ton intervention pour faciliter les retours d'expérience post-crise.

****Fin du document****

